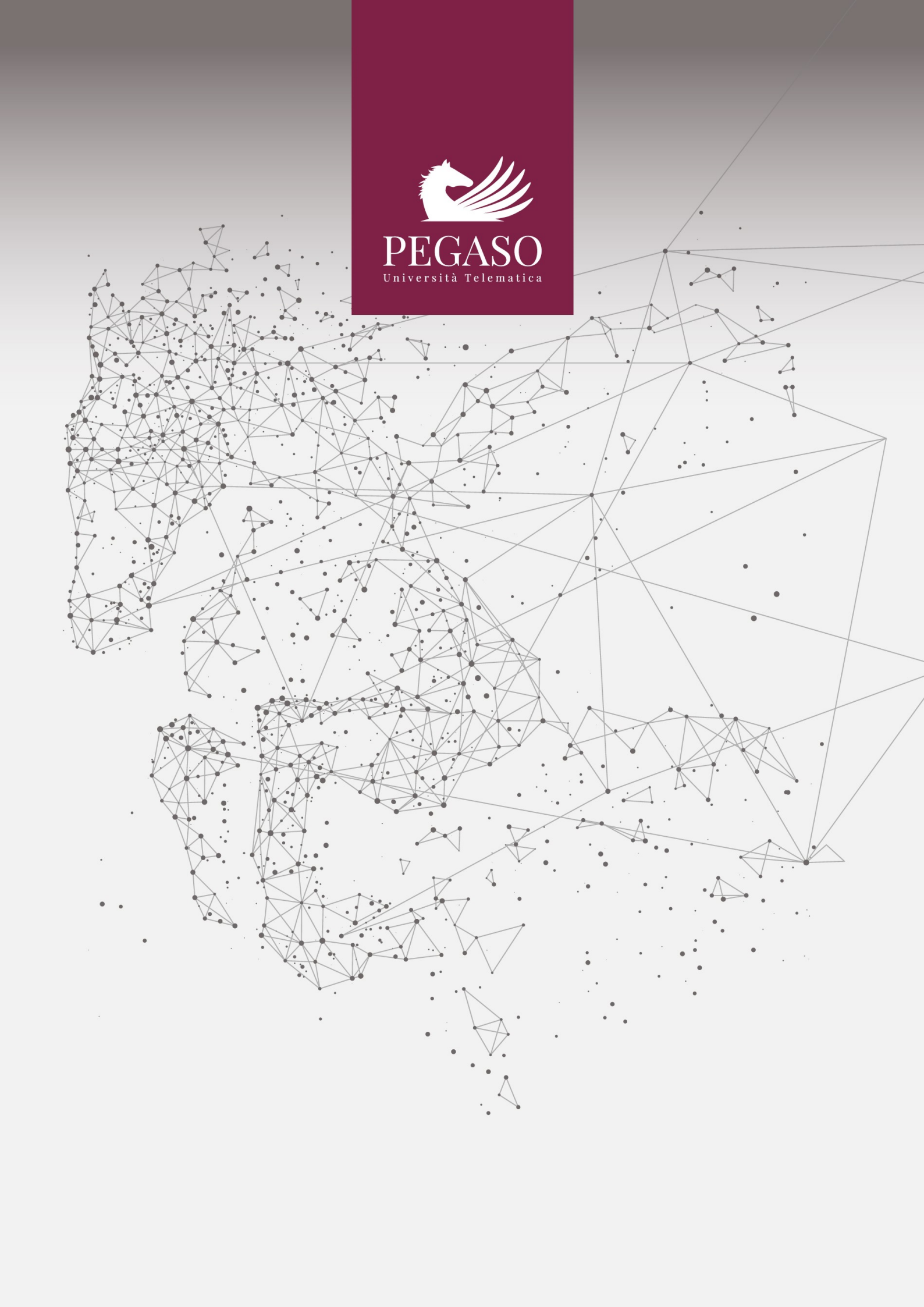

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 MOTIVAZIONI 3
2 KERBEROS V4: I PASSAGGI 4
3 KERBEROS V4: I PASSAGGI (FASE A) 5
4 KERBEROS V4: I PASSAGGI (FASE B) 7
5 KERBEROS V4: I PASSAGGI (FASE C) 9
BIBLIOGRAFIA 11

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Motivazioni

L'autenticazione in un ambiente distribuito aperto in cui esistono workstation e server presenta complicate problematiche di sicurezza.

- Un utente potrebbe guadagnare l'accesso a una certa workstation e fingersi un altro utente che normalmente opera da quella workstation
- Un utente potrebbe modificare l'indirizzo di rete della propria workstation in modo che la richiesta inviata dalla sua workstation sembri provenire da un'altra
- Un utente potrebbe intercettare gli scambi e utilizzare un attacco replay per riuscire ad entrare su un server

Non si possono implementare complicati protocolli di autenticazione su ogni server e quindi si preferisce utilizzare un **server di autenticazione centralizzato** che autentichi gli utenti verso i server e i server verso gli utenti. Tra le soluzioni utilizzate esiste **Kerberos V4** (sviluppato al MIT, basato su DES) che poi si è evoluto in **Kerberos V5** (standard per Internet).

Nella mitologia greca Cerbero era il cane a tre teste posto a guardia dell'ingresso dell'Ade.

Kerberos doveva soddisfare i seguenti requisiti:

- **Sicurezza** (basato sulla crittografia simmetrica)
- **Affidabilità** (impiegare un'architettura a server distribuiti ridondanti)
- **Trasparenza** (l'utente deve solo inserire la password)
- **Scalabilità** (supportare un gran numero di client e di server)

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

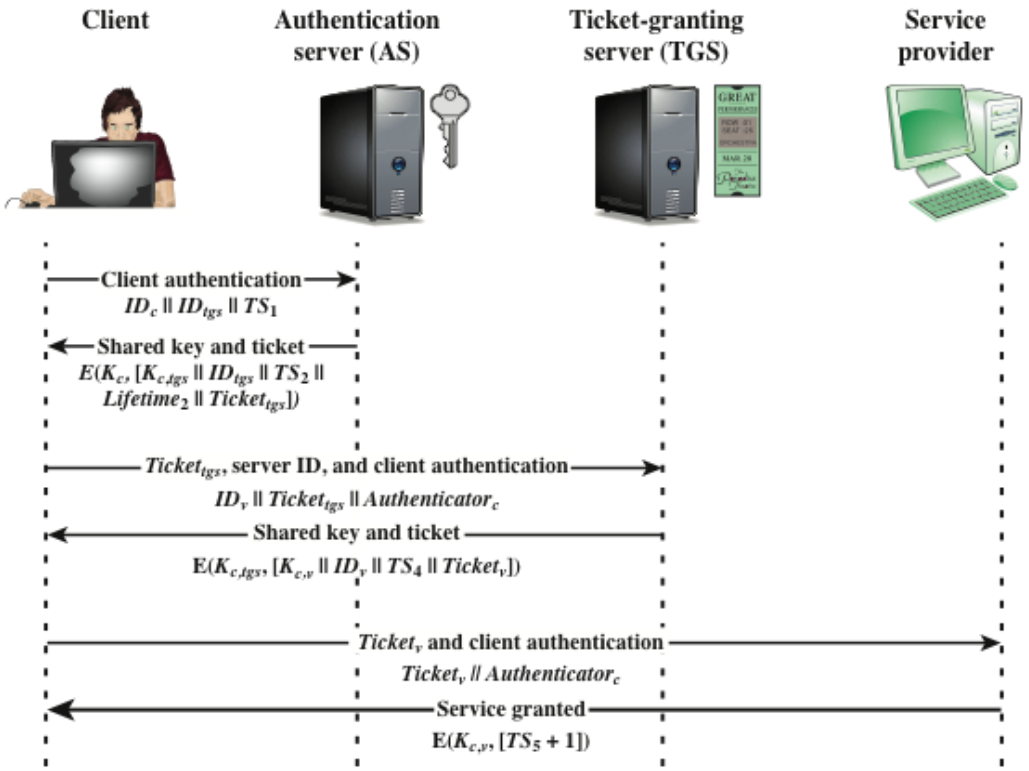
2 Kerberos v4: i passaggi

Esistono varie tipologie di implementazione del servizio Kerberos che si sono via via evolute così da risolvere alcuni dei problemi che si manifestavano; vediamo adesso la *versione 4* che è quella più completa così da avere una panoramica generale del funzionamento e dei vari aspetti in gioco.

In Kerberos V4 esistono due server di autenticazione:

- *AS (Authentication Server)* serve per consentire ad un utente (client) di autenticarsi in una sessione verso un server
- *TGS (Ticket-granting server):* serve per proteggere la password ed evitare che l'utente debba reintrodurre la password stessa per ogni nuovo servizio all'interno di una sessione

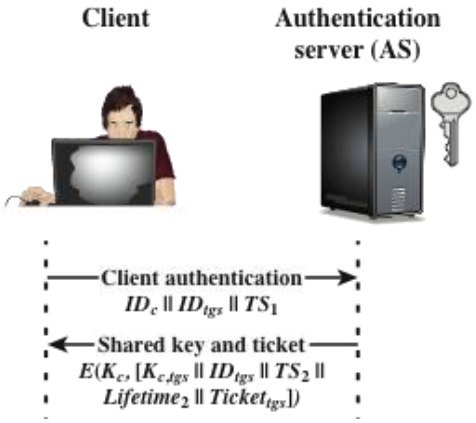
Nella figura sottostante è rappresentata la struttura globale del servizio Kerberos V4 con gli attori in gioco, la sequenza di messaggi scambiati e la loro tipologia.



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Kerberos v4: i passaggi (Fase A)

La prima fase di Kerberos V4 consiste nel dialogo fra il client e l'Authentication Server (AS) (vedi figura).



Il client C invia un messaggio al server di autenticazione (AS) richiedendo l'accesso al server TGS, in tale messaggio invia il suo identificativo ID_C, l'identificativo del server TGS a cui vuole accedere ID_{tgs} ed un timestamp TS_1.

– $ID_C \| \| ID_{tgs} \| \| TS_1$

A sua volta il server AS risponde con il seguente messaggio cifrato con la chiave del client K_c di cui è in possesso e derivata dalla password del client C:

– $E(K_c, [K_{c,tgs} \| \| ID_{tgs} \| \| TS_2 \| \| Lifetime_2 \| \| Ticket_{tgs}])$

Il messaggio è composto dalla chiave $K_{c,tgs}$ condivisa tra il client C e il server TGS, nuovamente l'identificativo ID_{tgs} del server TGS, un timestamp TS_2, un valore di durata e il $Ticket_{tgs}$

In questo modo la chiave di sessione $K_{c,tgs}$ viene consegnata in maniera sicura al client C che dispone ora anche del ticket $Ticket_{tgs}$ che è così fatto:

$$Ticket_{tgs} = E(K_{tgs}, [K_{c,tgs} \| \| ID_C \| \| AD_C \| \| ID_{tgs} \| \| TS_2 \| \| Lifetime_2])$$

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

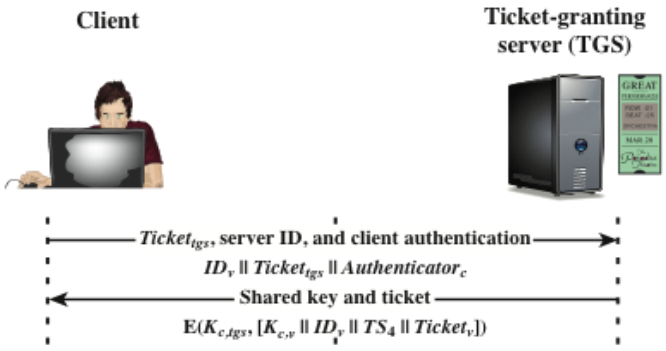
Il $Ticket_{tgs}$ è cifrato con la chiave K_{tgs} del server TGS (nota anche al server AS) e quindi solo TGS può aprire il ticket; tale ticket contiene la chiave condivisa $K_{c,tgs}$ tra il client C e il server TGS che quindi è ricevuta da TGS in modalità sicura, l'identificativo del client e il suo indirizzo, l'identificativo del TGS e nuovamente il timestamp TS_2 e la durata del ticket ($Lifetime_2$)

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

4 Kerberos v4: i passaggi (Fase B)

La seconda fase del protocollo Kerberos V4 riguarda il dialogo tra il client C e il server TGS, come evidenziato in figura.



A questo punto il client C contatta il server TGS e invia:

– $ID_V \,||\, Ticket_{tgs} \,||\, Autenticatore_C$

ovvero l'identificativo del server V con cui vuole parlare, il $Ticket_{tgs}$ ricevuto dal server AS e un autenticatore $Autenticatore_C$ che autentica il client C.

Tale autenticatore è così costituito:

– $Autenticatore_C = E(K_{c,tgs}, [ID_C \,||\, AD_C \,||\, TS_3])$

Esso è cifrato con la chiave di sessione K_{tgs}, di cui il server TGS è entrato in possesso dal ticket, e contiene l'identificativo del client e il suo indirizzo e un altro timestamp TS_3. Il server TGS a questo punto confronta l'identità del client, contenuta nell'autenticatore, con quella contenuta nel ticket, se il controllo è positivo allora è certo di parlare con il client C e che la chiave di sessione K_{tgs} sia corretta.

Infine il server TGS risponde al client C inviando il seguente messaggio cifrato con la chiave di sessione K_{tgs}:

– $E(K_{c,tgs}, [K_{c,v} \,||\, ID_V \,||\, TS_4 \,||\, Ticket_v])$

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Tale messaggio contiene la chiave di sessione $K_{C,V}$ condivisa tra il client C e il server V, l'identificativo del server V, un nuovo timestamp TS_4 e un ticket per il server V $Ticket_V$ cifrato con la chiave K_V del server V (nota appunto al server V e al server TGS) e così formato:

– $Ticket_V = E(K_V, [K_{C,V} \,||\, ID_C \,||\, AD_C \,||\, ID_V \,||\, TS_4 \,||\, Lifetime_4])$

Esso contiene la chiave di sessione $K_{C,V}$ condivisa tra il client C e il server V, l'identificativo e l'indirizzo del client C, l'identificativo del server V, lo stesso timestamp TS_4 e la durata del ticket ($Lifetime_4$).

È importante sottolineare che:

1. Il ticket $Ticket_{tgs}$ non dimostra l'identità di nessuno ma consente di distribuire in modo sicuro le chiavi

2. L'autenticatore dimostra l'identità del client

   – ha una vita breve

   – può essere usato una sola volta

   – non c'è il rischio che un estraneo possa sottrarre sia il ticket che l'autenticatore per ripresentarli in seguito

PEGASO
Università Telematica

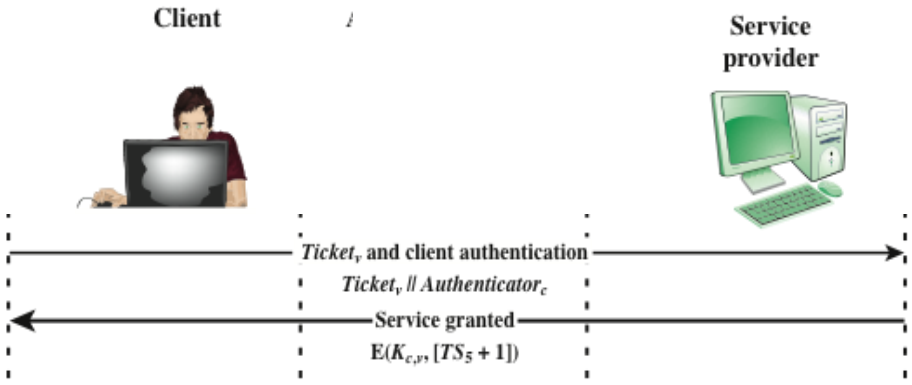
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

5 Kerberos v4: i passaggi (Fase C)

A questo punto il client C possiede un ticket di servizio $Ticket_V$ riutilizzabile con cui presentarsi al server V inviando:

– $Ticket_V \,||\, Autenticatore_C$

come indicato in figura.



L' autenticatore è così fatto:

– $Autenticatore_C = E(K_{C,V}, [ID_C \,||\, AD_C \,||\, ID_V \,||\, TS_5)]$

Il server V tramite la sua chiave K_V decifra il ticket e recupera la chiave di sessione $K_{C,V}$ condivisa tra il client C e il server V. Con tale chiave il server V può decrittografare l'autenticatore ricevuto dal client C e verificarne l'identità con quanto si trova nel ticket ricevuto $Ticket_V$.

Se è necessaria la reciproca autenticazione il server V può rispondere con il seguente messaggio:

– $E(K_{C,V}, [TS_5+1])$

Il client può leggere il messaggio usando la chiave di sessione $K_{C,V}$ e verificare il timestamp TS_5 incrementato. Tale messaggio garantisce il client C che i dati ricevuti non sono una replica a una vecchia risposta.

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Alla fine del protocollo, il client C e il server V condividono una chiave segreta che può essere utilizzata per:

- Crittografare i messaggi futuri che le due entità si devono scambiare
- Scambiarsi una nuova chiave di sessione

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitolo 14*.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).